

网络安全工程师是国家安全的守护者,中测安华运用钱学森系统工程的思维和方法,牢记初心,践行使命,逐步实现自主可控的安全突破,努力构建一个更安全的网络世界。

谈网络安全工程师的荣耀与担当 ——运用系统工程的思维和方法让网络世界更安全

◎ 中测安华副总经理 姚轶嶷
◎ 《中国信息安全》杂志社 彭琳

网络安全,国之大事,生死之地,因此维护网络安全的工程师已不仅是普通的技术人员,而是国家安全的守护者,他们为满足安全需求而生,为维护网络环境而战,网络系统延伸到哪里,网安人员就冲向哪里,使命光荣,担当重大。中测安华作为一支年轻的网安工程师专业队伍,成立五年来,运用钱学森系统工程的思维和方法,远离喧嚣,埋头苦干,沉淀技术,锻炼队伍,通过“静水流深”,塑造了独特的网络安防能力。本文首次将我们实践过程中的一些体会和做法予以梳理,旨在与志同道合者做一次有益的交流,共同维护网络世界的秩序与安全。

一、网络安全工程师对网络安全的追问与思考

作为一个不争的事实,网络空间是一个以“工程”(Engineering)方式构建的人造世界。用本不可信的人造产品(零件)构筑一个理想安全的网络世界,除了寄托着人们共同的愿景外,还真有可能并具有实际意义吗?这个问题一直困扰着我们。钱学森《系统工程论》关于“不可靠零件可以组成优秀系统”的论断给了我们重要启发。我们看到人

造世界与人造零件分属于两个不同范畴,前者属于“Safety”范畴,后者属于“Security”范畴。在工程实施过程中,由于“不同的拓扑结构在不同的攻击面前有不同的鲁棒性”,“Security”和“Safety”实际上完全可以逐渐统一为一个具有相对安全性的弹性工程(Resilience Engineering)。因此,坚持从攻击中发现防御之道,大力构筑使命工程(Mission Engineering),不断追求系统的抗打击力,就可以实现系统的“大安全”。

“从攻击中发现防御之道”,巧用对手思维构建安全系统。现有的IT系统,复杂程度已达到难以置信的水平,把信息安全工程做成信息化工程是业界普遍做法。业主方并没有意识到“信息安全是IT的立方,而不是IT的边角”,IT系统中总会出现无法及时发现的漏洞。同时,国家支持型黑客集团往往水平高超、资源充足,且极富耐心,很难将其攻击行为长期阻挡在系统之外。经验数据表明,安全攻防间存在非对称性,防御成本急剧上升、碎片化安全问题严重。面对不确定的安全环境,网络安全的假设已经发生了变化,假设已经遭遇违规、假设已经实现持久驻留是开展弹性设计的新起点,面对复杂的网络威胁,不要奢望去防护它,而是要

尽早地去发现它。发现漏洞的捷径往往在于尽早发现敌对一方的攻击行为，在于通过“漏洞分析和风险评估”的方式，透彻理解对手的行动方式，破敌“攻”而固己“防”。因此，站在高维视角通透理解信息系统安全生命周期全过程，将长期抗攻击实践中积累的网络安全知识纳入到基础工程技术流程当中，才能构建一个更具弹性的安全系统（Resilience Engineering），最大程度提升系统的抗攻击力，在自身系统与基础设施遭遇入侵的情况下仍可继续执行关键或基本任务。

构筑使命工程，增强系统抗打击力。没有网络安全就没有网络强国。安全是一种半公共产品，市场是安全创新的催化剂，以市场竞争的方式做安全无可厚非。但单点的创新并不一定能带来整体的集聚效益，这就带来了碎片化安全创新无法满足体系化安全需求的问题。对抗与防守的不对称性，从根本层面对支撑网络攻击与防御领域的经济形式提出了挑战。事实证明，网络安全是体系和体系之间的对抗，仅仅靠市场激励是远远不够的，必须一开始就从战略的高度思考安全问题，通过体系系统 SoS（SoS, System of Systems）分解到 System，分解到 Components，形成网络安全领域的体系化装备能力，这就是使命工程的重要性。作为对抗性系统，安全问题不只是系统的内在复杂性，更与组织行为和激励机制有关。只有从对抗意图和安全使命的高度进行任务分解，才能在设计建设某个局部安全系统时，就同时考虑到全局的体系系统协同能力。按照这个思路，我们在工程实践中总结出了一套“安全协同系统工程方法论”，我们的服务都是从战略合作协议签署的方式入手的，服务模式与传统安全公司从某个产品和单个项目切入不同，一开始就将自己定位为安全产业价值网络上的一个十分必要的关键节点，从战略的高度去设计系统、分解项目、联合产业界的力量为用户提供体系化的安全服务，用产业的心态做企业。

二、网络安全工程师对网络安全系统的实践与担当

对我国年轻的网络安全队伍而言，国家安全使

命不是一个飘忽的宏大概念，而是必须扎实地融入每个工程项目的具体工作。按照上述思路，多年来中测安华牢记初心，践行使命，一步一个脚印地实现了自主可控的安全突破。

利用关键技术突破，获得自主可控能力。一个网络安全队伍的诞生，通常源于一两个大型系统项目对安全自主可控的需求，并在项目建设过程中锻炼成长，中测安华亦是如此。六年前，中测安华核心团队承接了某大型央企的安全系统设计和软件研发任务，在对关键核心设备遂行安全检测时，发现存有后门。在国内没有自主可控替代产品的情况下，既要保证整体工程的顺利交付，又不能留下安全隐患，这使我们面临了巨大的考验。对此，我们组织专项研发队伍，突破技术难点，自主研发了安全产品，并在项目中大规模部署，实现了国产化的有效替代。安全难点有时会一通百通，解决了一个技术难点，便会带动一系列问题的迎刃而解。通过大工程带动小产品，发挥安全检测的技术海关作用，提升安全产业的自主创新能力，是我们摸索到的一条便捷之路。

巧借系统安全工程，提升安全保障能力。通过承接诸多重大信息安全工程项目，我们发现，网络安全队伍的发展模式与“网络安全领域系统工程院”的发展模式颇为类似。在这点上，我们借鉴了美国 MITRE 的经验，即为政府承建系统工程，形成研究开发和信息技术支持的非营利性组织。与 MITRE 不同的是，我们不只是作案头研究工作，更注重对工程本身的开发与完善。总结工程实践中的成功和失败案例，我们的结论是，对于一个大型网络安全工程项目而言，“信息安全”和“系统工程”两类知识是保障其顺利进行的必要前提，“大工程管理能力”和“大数据治理能力”是保障该工程项目顺利竣工的决定性因素。在大数据时代，大工程和大数据是相辅相成的，只有同时具备两种能力，才能使大项目工程系统既“立”起来，又“活”起来。关于这一点，我们教训深刻，在早期承担的网络安全大型项目中，我们也犯过只重“大工程管理能力”，忽视“大数据治理能力”的错误，从而导致项目工期拖延严重，工程系统难以有效运转。所以说，如何“用系统方法让网络

世界更安全”，我们也不是一开始就清楚的，而是在一个个大型项目工程的实践过程中一点一点摸索出来的。因此，若要将物理现实世界的工程方法应用到网络安全世界，还需要大量的工程实践，从美好蓝图到具体系统，有大量的细节要实现，这个过程亦是系统安全能力的提升过程。

设立总体设计部门，激发企业创新能力。网络安全队伍在为各大央企系统建设实践过程中，积累了战略级大型安全工程的实施经验，这恰恰是中国的优势之所在。能不能将零碎的成果汇成整体，将局部的经验变成全局指导，是检验网络安全队伍是否具有生命力、创新力的试金石。我们深刻意识到，系统工程需要高超的组织管理，唯有组织起来才是力量，才能把比较笼统的初始安全要求逐步地变为若干个研制任务参加者的具体工作，以及把这些工作最终综合成一个技术上合理、经济上合算、研制周期短、能协调运转的实际工程，并使该工程成为从属更大系统的有效组成部分。这样复杂的总体协调任务不可能靠个人来完成，个人也不可能精通整个系统所涉及的全部专业知识，不可能有足够的时间来完成数量惊人的技术协调工作。这就要求需以一种组织、一个集体来代替先前的单体指挥，对这种大规模社会劳动进行总体协调。为此，我们成立了“总体设计部”。“总体设计部”一般不承担具体部件的设计，却是整个系统研制工作中必不可少的技术抓总单位。“总体设计部”是系统工程中国学派的创新，曾在“两弹一星”大型工程中有过成功的实践。“总体设计部”的成立，大大提升了我们的控制和创新的能力。

搭乘“一带一路”快车，拓展企业发展空间。随着国家“一带一路”深化推进，给中国网络安全产业带来了溢出效应。一个央企的体量等同于“一带一路”上一个国家，其网络的复杂性、应用的丰富性、面临挑战的挑战性更有甚之。有了这样的建设经验，移植到其他国家的难度大大减小。不久前，我们承接了“一带一路”中两个国家的大型安全项目，由于有一套科学方法作指导，使得技术指挥线和管理指挥线清晰并重，工程在很短时间内便展开了有效施工。在“一带一路”宏图推进过程中，我们用“总

体设计部”思想做总体设计，凝聚中国智慧、传播中国理念、提供中国方案，为网络空间命运共同体贡献中国力量。同时，我们用大数据技术组装集成国内安全自主可控产品，形成了大规模分布式集群网络安全装备，如“望远镜”、“显微镜”、“透视镜”、“窥探镜”等系列装备，并实现了从商业级到国防级的技术转换。解决的难题主要包括，如何做国家级的安全顶层设计？如何做战略级的安全装备集成？如何做战术级的安全产品研发？这三个问题分别对应着“使命（Mission）、体系（System of Systems）、系统（System）”三个层面的架构和工程问题。这使我们积累了新的经验，拓展了新的天地。

三、网络安全工程师对网络安全愿景的展望与畅想

网络空间安全是什么标准，往何处去，是个大问题。我们虽然没有清晰的目标，却有明确的方向，即国家利益延伸到哪里，网络安全工程队伍就要保护到哪里，并用“风险驱动的安全价值网络”来回答网络空间安全标准问题，用“安全协同系统工程方法论（SecCSE）”来回答往何处去、怎么走的问题。构建网络空间命运共同体是人类共同的心声，但在大数据驱动的互联网时代，个体的力量总是有限的，只有嵌入到宏观协作中，才能发挥整体效益。我们构想，未来网络空间将在产业预判能力、系统设计能力及协同创新能力上聚焦发力，用系统安全工程方法构建一张“风险驱动的安全价值网络”（RiskSVN）。这张网络将实现各方互相协作、共同传递安全价值，以正能量维护网络世界的安全有序。

在这套思路中，有五个关键性元素，即：输入（Input）是安全保障对象；处理（Process）是系统安全工程；控制（Control）是安全参考框架；机制（Mechanism）是安全协同机制；输出（Output）是安全弹性系统。

输入是安全保障对象：安全工程与系统工程不一样，通常有一个需要保障的对象，从测评的角度称之为“TOE（Testing of Object）”，一切的安全需求都要围绕着被保护对象展开。保护对象的分解在安全设计中异常重要，这就是前面所说“信息安全

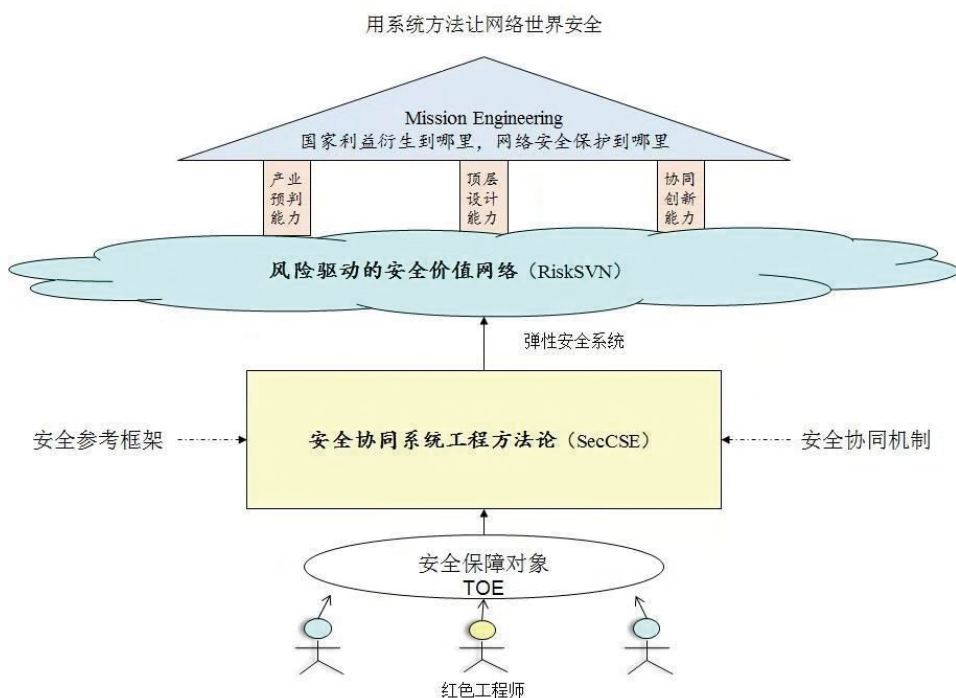


图1 基于系统思维维护网络安全思路

是IT立方的原因”，只有将被保护对象分析得清清楚楚，才能知道安全问题的核心所在，制定的安全措施才能有的放矢。

控制是安全参考框架：安全参考框架是指引性的，碎片化的安全问题需要体系化架构来指导，并由能力驱动的使能架构、体系架构、系统架构来解决，还需要从军事架构领域引入到安全架构领域，两者都有对抗性的特点。

机制是安全协同机制：安全协同机制不只是简单的技术协同，没有产业协同的经济利益机制设计，就没有产品设备层面的技术协同。安全协同机制要以“标准”为基础，“利益”做牵引。命运共同体即是“利益共同体”，对于一个企业，要推动安全协同机制的有效运转，一要在技术层面有安全标准制定；二要在运营层面有利益机制设计。并将安全标准对应到系统架构，利益机制对应到使能架构。

处理是系统安全工程：关注“信息安全”和“系统工程”两个世界的打通，安全测评方法和装备保障工程融入到系统安全工程，形成测评驱动的系统安全工程。“研制试验与评价(DT&E)”和“使用试验与评价(OT&E)”两者全面贯通系统工程生

命周期过程，从攻击中发现防御之道。

输出是安全弹性系统：安全智能化和安全自动化是网络安全的两个发展趋势，智能化提高对抗能力，自动化提升便利水平。未来安全可视化和安全智能化将更紧密地结合，可视化将拓展至解决安全问题，而不只是为安全信息特供可视化，人机将更紧密结合，发挥以人为主的形象思维优势。安全自动化和安全可度量相结合，还将拓展数据驱动的安全自动化。Making Security Measurable是MITRE的一项标准工程，只有标准化、自动化和智能化才有数据的基础，协同化网络才有可能，才能将安全弹性系统构成一张风险驱动的安全价值网络，实现“你的发现即我的防御”(图1)。

在马克思的墓碑上刻有两行文字：“以往的哲学家只是解释世界，而问题在于改造世界。”冯·卡门说“科学家研究已有的世界，工程师创造未来的世界。”安全不仅在于发现问题，更在于解决问题。笔者再次郑重呼吁，应赋予“网络安全工程师”新的使命与荣耀，并造就大批量善开拓、有担当的“红色安全工程师”，了然攻防之道，永存敬畏之心，守护国家安全，用系统工程的方法构建一个更安全的网络世界。**C**